

Sample AAA Security Policy — Zomato-like Food Delivery App

1. Authentication — “Who are you?”

Action	Authentication Required
Customer login	Yes — password/OTP
Restaurant partner login	Yes — password + MFA
Delivery partner login	Yes — password/OTP
Place an order	Yes — authenticated customer
View order history	Yes
Make a payment	Yes — additional payment verification when required
Access admin dashboard	Yes — password + MFA

2. Authorization — “What are you allowed to do?”

Role	Authorized Actions
Customer	Browse restaurants, place orders, make payments, view/cancel eligible orders, view own order history
Restaurant Partner	Manage own restaurant menu, accept/reject orders, update order status, view own restaurant orders
Delivery Partner	View assigned deliveries, update delivery status, view necessary delivery information
Support Agent	View customer/order information required for support and update permitted support fields
Administrator	Manage users, restaurants, delivery partners, security policies, and system configuration

Principle of least privilege: Each role should receive only the permissions required to perform its job.

3. Accounting — “What did you do?”

- Successful and failed login attempts
- Logout and session events
- Password/OTP changes
- MFA events
- Order creation, cancellation, and status changes
- Payment attempts and transaction status
- Changes to restaurant menus

- Delivery-status updates
- Administrator actions
- Permission/role changes
- Suspicious or unusual access attempts

Each important log should include information such as timestamp, user/account identifier, action, result (success/failure), source/device information where appropriate, and relevant transaction/request ID. Logs should be protected against unauthorized modification and retained according to the organization's security and legal requirements.

Security Improvement I Would Make

 **Require step-up MFA for high-risk administrative actions.**

Even if an administrator is already logged in, changing user permissions, disabling security controls, or accessing highly sensitive information should require MFA/step-up verification again. This adds an extra security layer if an administrator's existing session or password is compromised.